Profil Resmi Yönetimi

Backend & Frontend Teknik Şartname ve Mimari Dokümanı

1. Amaç

Kullanıcının kendi profil fotoğrafını yükleyebilmesi, görüntüleyebilmesi, değiştirebilmesi ve silebilmesi için gerekli olan backend altyapısının, yükleme güvenliği kriterlerinin ve frontend kullanıcı arayüzü gereksinimlerinin standartlaştırılmasıdır.

2. Backend Mimarisi ve Veritabanı Tasarımı

Profil resmi bilgilerini saklamak için ihtiyaca göre iki alternatif yaklaşım mevcuttur:

Yaklaşım A: Mevcut Tabloya Ekleme (`Users` Tablosu)

Tek bir aktif profil resminin tutulmasının yeterli olduğu senaryolarda tercih edilir.

- `ProfileImagePath` : Dosyanın sunucudaki veya bulut depolamadaki (S3 vb.) erişim yolu.
- `ProfileImageName` : Sunucu tarafında benzersiz olarak oluşturulmuş dosya adı.
- `ProfileImageUpdatedAt` : Profil resminin son güncellenme zaman damgası (Timestamp).

Yaklaşım B: Ayrı Tablo Oluşturma (`UserProfileImages` Tablosu)

İlerleyen süreçlerde profil fotoğrafı geçmişi (history) tutulacaksa veya eski fotoğraflara geri dönülmek isteniyorsa bu mimari daha temiz bir yapı sunar.

3. Endpoint Yapılandırması

Seçenek 1: Tam RESTful Standart (CRUD)

Metot	Endpoint	Açıklama
`POST`	`/api/profile/image`	Yeni profil resmi yükler.

Metot	Endpoint	Açıklama
GET	`/api/profile/image`	Aktif profil resmini veya bilgilerini getirir.
PUT	`/api/profile/image`	Mevcut profil resmini yenisiyle değiştirir.
DELETE	`/api/profile/image`	Mevcut profil resmini siler.

Seçenek 2: Basitleştirilmiş Yapı

Metot	Endpoint	Açıklama
POST	`/api/profile/image`	Profil resmi yükleme ve mevcut varsa güncelleme.
DELETE	`/api/profile/image`	Profil resmini kaldırma.

4. Dosya Yükleme Güvenliği (Upload Security)

Backend tarafında kesinlikle sadece kullanıcıdan gelen dosya uzantısına güvenilmemelidir. Aşağıdaki güvenlik kontrolleri zorunludur:

- **Maksimum Dosya Boyutu:** Belirlenen üst limit kontrol edilmelidir (Örnek Limit: `5 MB`).
- **İzin Verilen Formatlar:** Yalnızca `.jpg`, `.jpeg`, `.png`, `.webp` kabul edilir.
- **İzin Verilen MIME Türleri:** `image/jpeg`, `image/png`, `image/webp` doğrulaması yapılmalıdır.
- **Gerçek İçerik Kontrolü:** Dosyanın Magic Bytes / File Header bilgileri incelenerek gerçek bir resim dosyası olduğu doğrulanmalıdır.
- **Güvenli Dosya Adı Oluşturma:** Kullanıcının gönderdiği dosya adı kullanılmamalı; sunucuda rastgele/kriptografik güvenli (UUID/GUID) dosya adı üretilmelidir.
- **Path Traversal Engellenmesi:** `../` gibi dizin üstüne çıkma dizgileri temizlenmeli ve engellenmelidir.
- **Executable / Çalıştırılabilir Dosyalar:** Betik veya kod çalıştırabilecek dosyalar kesinlikle reddedilmelidir.
- **Boş veya Bozuk (Corrupt) Dosya Kontrolü:** 0 byte veya işlenemeyen resim dosyaları reddedilmelidir.

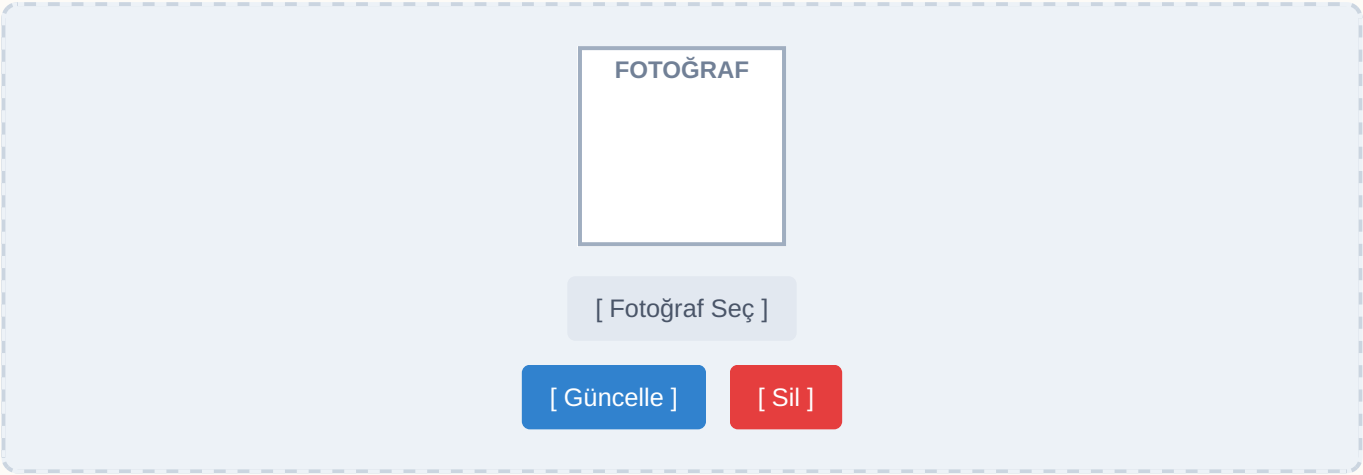
5. Yetkilendirme (Authorization)

Kullanıcı yetki sınırları sıkı bir şekilde denetlenmelidir:

- Kullanıcı yalnızca kendi profil resmini değiştirebilir.
- `User A → User A resmi` ✅ **Kabul Edilir**
- `User A → User B resmi` ❌ **Reddedilir (HTTP 403 Forbidden)**
- `Admin` yetkisine sahip kullanıcılar sistem politikalarına göre müdahale edebilir.

6. Frontend Arayüzü ve Akışı

Kullanıcı Arayüzü Şeması



Adım Adım Yükleme Akışı

- **1. Dosya Seçimi:** Kullanıcı cihazından resim dosyasını seçer.
- **2. İstemci Kontrolü:** İstemci tarafında hızlı boyut ve uzantı kontrolü yapılır.
- **3. Önizleme (Preview):** Seçilen fotoğraf yüklenmeden önce anlık olarak ekranda gösterilir.
- **4. Upload İsteği:** İlgili endpoint'e multipart/form-data isteği atılır.
- **5. Loading Göstergesi:** Yükleme süresince kullanıcıya yükleniyor animasyonu/spinner gösterilir.
- **6. Bildirim:** İşlem sonucuna göre başarılı/başarısız mesajı bildirilir.